



Logical Access Management

October-2021
Version 1.0

+971 2 507 5000

www.massarsolutions.ae



Table of contents

1. Purpose	5
2. Scope	5
3. Responsibilities	5
4. Policy	5
5. Password Specifications	6

Document Signoff		
Position	Signature	Date
IT Manager		3-November-2021
CEO		07 November 2021

Document Change Record			
Version	Date	Change Reference	Remarks / Clause No.
1.0	19-10-2021	First issue and implementation	All

1. Purpose

- 1.1 Protecting access to IT systems and applications is critical to maintain the integrity of the Massar Solutions technology and data and preventing unauthorized access to such resources.
- 1.2 Access to Massar's systems is restricted to only authorized users or processes, based on the principle of the strict need to know and least privilege.

2. Scope

- 2.1 All IT systems or applications managed by Massar solutions that store, process, or transmit information, including network and computer hardware, software and applications, mobile devices, and telecommunication systems.

3. Responsibilities

- 3.1 IT Manager is responsible for overall implementation, maintaining of this Policy document, and is to ensure that the Policy is communicated to all Massar employees and adhered to.
- 3.2 Circulation of this document and subsequent updates are controlled and monitored by the IT Manager in line with the Control of Document (MAS-QH-PR-001).

4. Policy

4.1 General Requirements

- 4.1.1 Requests for users' accounts and access privileges must be formally documented and appropriately approved.
- 4.1.2 All requests shall formally be logged and approved on the IT Service desk.
- 4.1.3 Requests for special accounts and privileges (such as vendor accounts, application, and service accounts, system administration accounts, shared / generic accounts, test accounts and remote access) must be formally documented and approved by the system owner.
- 4.1.4 Application and service accounts must only be used by application components requiring authentication; access to the passwords must be restricted to authorized IT administrators or application developers only.
- 4.1.5 Where possible, the IT department will set user accounts to automatically expire at a pre-set date.
- 4.1.6 When temporary access is required, such access will be removed immediately after the user has completed the task for which the access was granted.
- 4.1.7 User accounts assigned to contractors will be set to expire according to the contract's expiry date.
- 4.1.8 User accounts will be disabled after 3 months of inactivity.
- 4.1.9 Access rights will be immediately disabled or removed when the user is terminated
- 4.1.10 Existing user accounts and access rights will be reviewed at least annually to detect dormant accounts and accounts with excessive privileges. Examples of accounts with excessive privileges include.
 - 4.1.10.1 An active account assigned to external contractors, vendors, or employees that no longer work for the Institution.
 - 4.1.10.2 An active account with access rights for which the user's role and responsibilities do not require access. For example, users that do not have the authority or responsibility to approve expenses should not have access to approval permissions within a financial system.
 - 4.1.10.3 System administrative rights or permissions (including permissions to change the security settings or performance settings of a system) are granted to a user who is not an administrator.

4.1.10.4 All-access requests for system and application accounts and permissions will be documented and logged on Service Desk.

4.2 Privileged Accounts

4.2.1 A nominative and individual privileged user account must be created for administrator accounts (such as "first_name.last_name.admin"), instead of generic administrator account names.

4.2.2 Privileged user accounts can only be requested by managers or supervisors and must be appropriately approved.

4.3 Shared User Accounts

4.3.1 Where possible, the use of specific network domain "security groups" should be used to share common access permissions across many users, instead of shared accounts.

4.3.2 Shared user accounts are only to be used on an exception basis with the appropriate approval. This includes general user accounts such as "guest" and "functional" accounts.

4.3.3 When shared accounts are required:

4.3.3.1 Passwords will be stored and handled following the Password specifications.

4.3.3.2 The use of shared accounts will be monitored where possible, including the recording of the time of access, the reason for accessing the shared user account, and the individual accessing his account.

4.3.3.3 When the shared user account has administrative privileges, such a procedure is mandatory and access to the monitoring logs must be protected and restricted.

4.4 Vendor or Default User Accounts

4.4.1 Where possible, all default user accounts will be disabled or changed. These accounts include "guest", "temp", "admin", "Administrator", and any other commonly known or used default accounts, as well as related default passwords used by vendors on "commercial off-the-shelf" systems and applications and appliances.

4.5 Access Control Requirements

4.5.1 All users must use a unique ID to access Massar systems and applications. Passwords must be set following the Password specifications.

4.5.2 Remote access (VPN) to Massar Solutions systems and applications must use two-factor authentication

5. Password Specifications

5.1 Password minimum requirements:

5.1.1 Password length to be set to at least 8 characters.

5.1.2 Password must:

5.1.2.1 Contain at least one lower character

5.1.2.2 Contain at least one upper character

5.1.2.3 Contain at least one digit character

5.1.2.4 Contain at least one special character

5.1.2.5 Lock accounts after 4 unsuccessful login attempts with no auto-enabled function.

5.1.2.6 Users to be forced to change their passwords every 12 weeks.

5.1.2.7 Idle session timeout to be set to 15 minutes.

5.1.2.8 Password history configured to remember all passwords for 1-year i.e., the last 4 passwords.